

AI Policies and Procedures

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 22: Organizational Governance for AI

1. The Gap Between Governance Intention and Operational Reality

The CoE establishes governance structure. Governance principles establish direction. But neither tells a data scientist on a Tuesday afternoon what to do when a stakeholder asks them to expand a fraud detection model to a new demographic segment. That gap — between governance intention and operational reality — is exactly what AI policies and procedures are designed to close. A policy states a requirement. A procedure specifies how to meet it. Together, they translate governance commitments into concrete, consistent, daily practice.

The most important thing to understand about AI policies is that a vague policy is not better than no policy. It is actually worse — it creates the appearance of governance coverage while providing none of the operational clarity governance is supposed to deliver. 'AI shall be used ethically and responsibly' is a value statement. It cannot be tested for compliance. Different teams will apply it differently, governance consistency disappears, and the document becomes evidence of a checkbox exercise rather than operational discipline.

Policy vs. procedure: A policy states a requirement ('AI systems making credit decisions must provide a human-reviewable explanation for each decision'). A procedure specifies how to meet it ('use SHAP or LIME, include the top five contributing features, store results in the governance repository'). Both are required. Neither alone is sufficient.

2. The Policy Hierarchy

Mature organizations structure AI governance documentation in four distinct layers. Conflating these layers — writing principles and calling them policies, or writing procedures and labeling them standards — is one of the most common governance documentation failures because each layer has a different owner, update cadence, and enforcement mechanism.

Layer	Description	Owner	Update Cadence
Principles	High-level commitments reflecting organizational values. Example: 'AI decisions affecting individuals must be explainable and contestable.'	Executive leadership / Board	Rarely — tied to organizational values
Policies	Specific requirements flowing from principles. Example: 'AI systems making credit decisions must provide a human-reviewable explanation for each decision.'	CoE / Legal / Compliance	Annually + triggered reviews
Standards	Technical specifications implementing policies. Example: 'Credit AI explanations must be	CoE / Technical leads	Annually + when technology changes

	generated using SHAP or LIME, including the top five contributing features.'		
Procedures	Step-by-step instructions with templates, tooling, and review workflows for implementing standards.	CoE / Platform teams	Continuously as tooling evolves

3. Policy Types Across the AI Lifecycle

AI policies must address every phase of the AI lifecycle. Policies that only cover deployment while ignoring operational drift and decommissioning leave persistent governance gaps that adversaries and regulatory auditors both exploit.

- Development policies — What testing must occur before a model leaves a development environment? What documentation must exist before entering the review queue? What data governance standards apply to training data sourcing?
- Deployment policies — What approval workflow must be completed before production deployment? What monitoring must be in place before go-live? What access controls must protect the inference API?
- Operational policies — How often must model performance be re-evaluated against production data? What drift thresholds trigger a mandatory re-review? Who must be notified when a threshold is breached?
- Decommissioning policies — How must AI systems be retired? What happens to training data, model artifacts, and audit logs when a system is decommissioned? Who authorizes decommissioning?

The policy gap exploited in the healthcare attack scenario (below) is an operational phase gap: the organization's policy covered initial deployment review but had no policy governing third-party model updates to existing systems. This left the operational phase ungoverned for the most consequential lifecycle event after initial deployment.

4. Attack Scenario: Policy Gap in Third-Party Model Updates (Healthcare)

Real-World Scenario — Healthcare AI Policy Gap (Operational Phase): A healthcare AI vendor delivered a clinical decision support tool to a hospital network under a contract allowing model updates without customer approval as long as accuracy metrics were maintained. The hospital's AI policy covered initial deployment review but had no policy governing third-party model updates to existing systems. Six months after deployment, the vendor retrained the model on data from a different patient population, shifting performance characteristics affecting specific clinical pathways. The hospital's governance process never triggered. An adversary with access to the vendor's training pipeline then introduced data poisoning targeting a specific clinical segment — exploiting the same policy gap that allowed legitimate updates to proceed without review. The lesson: policies that cover only initial deployment create persistent governance blind spots for the operational phase, and those blind spots are attack surfaces.

5. Writing Policies That Practitioners Can Use

Effective AI policies share structural characteristics that practitioners can apply without interpretation — which is the goal, because interpretation variance is where governance consistency breaks down.

Characteristic	Description	Example of Failure Without It
Specific	Requirements reference defined terms, documented procedures, and measurable thresholds — not aspirational language	'AI shall be tested for bias' vs. 'AI systems classified as high-risk must undergo bias testing across all demographic groups listed in [procedure reference] before deployment approval'
Proportional	Requirements scale with risk tier — high-risk AI has more demanding requirements than low-risk	Applying full conformity requirements to an internal scheduling tool creates governance overhead that drives shadow deployment
Justified	Policy explains why the requirement exists — increases compliance and helps practitioners apply spirit in edge cases	Without justification, practitioners cannot make correct judgment calls in novel situations
Scoped	Explicit boundaries: who is covered, what types of AI, what the exceptions are	Without explicit exceptions, every edge case becomes a governance negotiation
Cross-referenced	Links to related procedures, escalation paths, and policy violation response	Without cross-references, practitioners who encounter violations do not know what to do next

6. Acceptable Use Policies: Defining Boundaries

Acceptable use policies answer the question practitioners face constantly: is this a legitimate use of AI in our organization? A well-constructed AI acceptable use policy explicitly names prohibited uses — applications the organization has determined are outside acceptable boundaries regardless of technical feasibility. Standard prohibited uses across governance frameworks include:

- Fully automated consequential decisions about individuals without human oversight — affecting employment, credit, healthcare, or legal status.
- AI systems designed to deceive users about the existence or nature of AI involvement — undisclosed chatbots presenting as humans, synthetic media without disclosure.
- Surveillance of employees or customers without a disclosed legal basis.
- Processing personal data for AI training without an established legal basis under applicable privacy law.

Acceptable use policies must also define the approval pathway for novel use cases — cases where the organization has not yet decided whether the use is permitted. Without this pathway, teams either wait indefinitely for a decision or proceed without authorization. Both outcomes are governance failures. The pathway should specify who makes the novel-use determination, what evidence is required, and what the expected timeline is.

7. Data Governance Policies for AI

AI systems are only as trustworthy as the data they are built on. Data governance policies for AI address several concerns that predate-AI data governance frameworks typically miss:

- Training data quality — what standards must training data meet for accuracy, completeness, and representativeness? Who certifies that training data meets those standards before model development begins?
- Data provenance — every training dataset must have documented lineage: where it came from, how it was processed, what transformations were applied. This connects directly to model supply chain integrity.
- Personal data in training — what legal basis authorizes use? What data minimization measures are in place? What are retention limits for training data once the model is in production?
- Synthetic data validation — if synthetic data augments training, what process validates that it does not introduce artifacts corrupting model behavior or amplifying existing biases?
- Third-party training data — what due diligence is required for datasets sourced externally? What contractual representations are required about data origin, consent, and accuracy?

These concerns connect directly to the AI supply chain security principles from earlier sections. Data poisoning attacks often exploit gaps in training data provenance policies — if an organization cannot trace where training data came from, it cannot detect whether it has been tampered with.

8. AI Security Policies: Connecting Technical and Governance Layers

AI governance policies must explicitly incorporate the security requirements covered in earlier sections. Without explicit policy mandates, security requirements remain aspirational and are not consistently applied. AI security policies should mandate:

- Adversarial robustness testing for AI systems exposed to adversarial input environments — not optional for production systems in high-risk applications.
- Model integrity verification throughout the ML supply chain — model artifacts signed, provenance tracked, registry write access controlled and monitored.
- Access control requirements for training infrastructure, model registries, and inference APIs — including RBAC, audit logging, and anomaly detection on write operations.
- Incident response procedures for AI-specific failure modes: model extraction attacks, inference attacks, adversarial input campaigns, and data poisoning.
- Third-party AI risk requirements for vendor-supplied models and AI APIs — vendor risk assessment in the procurement chain, not after contracts are signed.

AI security policies require annual review at minimum, with updates triggered whenever new attack classes are operationally demonstrated. The attack surface for AI changes faster than for conventional software — policies must evolve at the same pace or they become outdated coverage that creates false assurance.

9. Red Team Perspective: Social Engineering Around Policy Exceptions

Red Team Scenario — Social Engineering the Exception Process: AI policies almost always include

exception processes for teams to request waivers from requirements that do not fit their specific context. These exception processes are a social engineering target. In a documented red team exercise, an attacker with access to an internal Slack workspace identified an AI project team frustrated with the governance review timeline. Posing as a CoE governance specialist in a direct message, the attacker offered to 'expedite' the review through an informal exception process, asking the team to share model artifacts and training data documentation through a file sharing link for an 'accelerated review.' The data scientist complied after a three-week wait for official review. Mitigations: digitally signed communications for all exception approvals, published exception process workflows practitioners can verify they are following, and anomaly monitoring for exception requests that route through unofficial channels.

10. Procedures: From Policy to Practice

Procedures are what make policies operational. A policy might require that 'AI systems must undergo fairness testing before deployment.' The procedure specifies exactly what that means in practice:

- What fairness metrics to compute — demographic parity, equalized odds, individual fairness as applicable to the use case and affected protected characteristics.
- Which tool to use — specify exact tool and version: 'IBM AI Fairness 360, accessed through the CoE platform at [URL],' not 'a bias testing tool.'
- What demographic subgroups to evaluate — defined by applicable employment, credit, or healthcare law for the deployment context.
- What the pass/fail thresholds are — explicit numeric thresholds, not qualitative assessments.
- How to document results and where to store them — specific repository, specific template, specific fields required.
- What happens if the system fails the gate — remediation path, escalation, re-test cycle, and who must be notified.

Without the procedure, different practitioners perform fairness testing in incompatible ways, produce results that cannot be compared, and the policy requirement becomes a box-checking exercise. The procedure is where governance quality is actually determined — not the policy.

11. Policy Enforcement: Creating Real Accountability

Policies without enforcement are suggestions. Three enforcement mechanisms, used in combination, create real accountability:

Enforcement Type	How It Works	Strength
Structural enforcement	Build policy compliance into the workflow itself. Deployment pipelines require a signed-off governance checklist before production promotion.	Cannot be bypassed without visible process deviation; operates at scale without manual oversight
Audit-based enforcement	Periodic reviews of deployed systems against policy requirements by CoE or internal audit, with findings reported to leadership.	Detects post-deployment drift; provides accountability evidence for regulatory review
Metric-based	Compliance rates tracked by business unit,	Creates competitive

enforcement	included in leadership reporting — accountability without direct intervention.	accountability; surfaces systemic non-compliance patterns
-------------	--	---

Consequence design must be explicit, graduated, and consistently applied. First violations trigger coaching and remediation. Patterns of deliberate circumvention require escalation. The EU AI Act creates criminal liability for deliberate non-compliance with high-risk AI requirements — external enforcement pressure is increasingly complementing internal mechanisms and raising the stakes for organizations that treat policies as suggestions.

12. Policy Maintenance and Communication

AI governance policies written in 2022 are likely missing requirements that are now mandatory. Maintaining policy currency requires a formal review cycle — annually at minimum, with triggered reviews when significant regulatory changes, major incidents, or new threat intelligence emerge.

Policy maintenance inputs: gap analysis against current regulatory requirements, comparison with industry peer practices, review of incident findings for policy gaps, and technical review to ensure references to specific tools or standards are current. Every policy version must be archived with its effective date visible — practitioners who read an archived version believing it is current create compliance gaps.

Policy communication must be as deliberate as policy content. A policy that nobody knows about does not function. Effective communication includes: announcing new policies through channels practitioners actually use (team meetings, engineering Slack channels), explaining the rationale behind requirements, integrating policies into onboarding for AI-relevant roles, and maintaining a searchable policy repository. Write policies for the practitioners who will follow them, not for the legal team that approved them. Plain language governance documentation is a prerequisite for governance that functions, not a compromise.

Key Terms Glossary

Term	Definition
AI Policy	A specific, testable requirement that flows from governance principles and defines what practitioners must do in relation to AI systems
AI Procedure	Step-by-step instructions specifying how to meet a policy requirement, including tooling, templates, thresholds, and escalation paths
Policy Hierarchy	Four-layer governance documentation structure: Principles → Policies → Standards → Procedures, each with distinct owner, update cadence, and enforcement
Acceptable Use Policy	Governance document explicitly defining prohibited AI uses, permitted uses, and the approval pathway for novel use cases
Data Provenance	Documented lineage of training data: origin, processing history, transformations applied — required by data governance policy for all training datasets

Structural Enforcement	Policy compliance built into technical workflows (e.g., deployment pipelines requiring governance checklist sign-off before production promotion)
Policy Exception Process	Formal mechanism for requesting waivers from policy requirements; a social engineering target requiring authentication controls and anomaly monitoring
Drift Threshold	Operational policy parameter defining the level of production data distribution shift or performance degradation that triggers mandatory model re-review
Novel Use Case Pathway	Defined approval process for AI use cases not yet covered by existing acceptable use policy — prevents unauthorized deployment and extended waiting
Responsible Use Constraints	Explicit governance requirements defining what AI practitioners may not do autonomously, with enforcement through approval gates and documented consequences

Quick Revision Checklist

- Policy states a requirement; procedure specifies how to meet it. Both are required — neither alone is sufficient.
- Four policy hierarchy layers: Principles, Policies, Standards, Procedures — each has a different owner, cadence, and enforcement mechanism.
- AI policies must cover all lifecycle phases: development, deployment, operational, and decommissioning. Gaps in any phase create attack surfaces.
- Effective policies are specific, proportional, justified, scoped, and cross-referenced — vague policies create interpretation variance and false assurance.
- Acceptable use policies must name prohibited uses AND define the approval pathway for novel use cases.
- Data governance policies for AI must address training data quality, provenance, personal data legal basis, and synthetic data validation.
- AI security policies must mandate adversarial robustness testing, model artifact signing, access controls, AI-specific IR procedures, and third-party risk requirements.
- Policy exception processes are social engineering targets — require digitally signed approvals and anomaly monitoring for unofficial exception channels.
- Three enforcement types: structural (pipeline gates), audit-based (periodic reviews), metric-based (compliance rates in leadership reporting).
- Policy maintenance: annual review minimum, version control, effective date visible, triggered reviews on regulatory changes or significant incidents.

10 Exam-Based MCQs — AI Policies and Procedures

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: *The post-deployment audit was triggered after a regulatory inquiry about the organization's AI systems making clinical triage decisions affecting elderly patients, who were found to have materially different outcomes than younger patients. A healthcare organization's AI governance policy states: 'AI systems must undergo fairness testing before deployment.'* A post-deployment audit finds that three teams interpreted this requirement differently — one computed demographic parity across five subgroups, one ran a general accuracy audit, and one asked a subject matter expert to review outputs qualitatively. Which governance document is MOST urgently needed?

- A) An updated policy that adds more detail about what 'fairness' means in principle
- B) A procedure specifying the exact fairness metrics, tooling, demographic subgroups, thresholds, documentation, and escalation path
- C) A principle-level statement affirming the organization's commitment to non-discriminatory AI
- D) A standard naming acceptable fairness testing vendors for procurement

Answer: B **Explanation:** B is correct because the problem described is interpretation variance — the policy requirement exists but practitioners cannot apply it consistently because no procedure specifies how to meet it. A procedure resolves this by eliminating interpretation. A is wrong because adding principle-level detail to a policy does not resolve the operational inconsistency. C is wrong because a principle is one level above policy and does not address the operational gap. D is wrong because a standard naming vendors is part of the picture but does not resolve the full implementation gap described.

Q2. Scenario: *The vendor contract specified that updates preserving overall accuracy metrics did not require customer approval. The organization's governance framework had no policy referencing this contract provision or governing vendor update scenarios. An organization's AI policy covers initial deployment review but has no policy governing model updates from third-party vendors. A vendor retrain a clinical decision support model on a new patient population without customer notification. This creates a governance gap that an adversary later exploits. Which policy type would MOST directly have prevented this gap?*

- A) Development policy — requiring documentation of all model training approaches before initial deployment
- B) Acceptable use policy — prohibiting AI in clinical decision support without board approval
- C) Operational policy — governing third-party model updates to existing production systems
- D) Decommissioning policy — requiring vendor notification before system retirement

Answer: C **Explanation:** C is correct because the gap is specifically in the operational phase — what governs an existing deployed system after initial approval. An operational policy covering third-party model updates would have required a review trigger when the vendor retrained the model. A is wrong because development policy covers pre-deployment model training within the organization; this is a vendor update to a deployed system. B is wrong because an acceptable use policy addresses whether clinical decision support AI is permitted, which is not the issue. D is wrong because decommissioning policy covers retirement, not active updates.

Q3. Scenario: *The data scientist's team had been waiting three weeks for official governance review of a model they needed to deploy before an upcoming product launch. The review queue was documented as*

having a four-to-fourteen week median wait time. A data scientist receives a direct message from someone claiming to be a CoE governance specialist, offering to expedite her AI project's governance review through an unofficial process and asking her to share model artifacts via a file sharing link. Which governance control would MOST directly have helped her identify this as a potential social engineering attempt?

- A) A policy prohibiting data scientists from communicating with CoE staff through instant messaging platforms
- B) Published exception process workflows specifying the official channels and authentication requirements for governance expedites
- C) A mandatory annual social engineering awareness training program for AI practitioners
- D) A policy requiring all governance reviews to be completed within four weeks to eliminate the frustration that makes teams vulnerable

Answer: B **Explanation:** B is correct because published exception process workflows allow practitioners to verify whether a request is following the official process. If the official exception process requires digitally signed approvals through a specific portal, an unofficial request through Slack is immediately identifiable as inconsistent with the known process. A is wrong because restricting communication channels does not give practitioners a way to verify whether a communication is authentic. C is wrong because training alone does not give practitioners a verification mechanism — it raises awareness but doesn't resolve the specific verification challenge. D is wrong because reducing review time addresses the vulnerability's root cause (frustration) but not the authentication verification mechanism.

Q4. Which policy hierarchy layer is responsible for specifying that 'credit AI explanations must be generated using SHAP or LIME and must include the top five contributing features'?

- A) Principles
- B) Policies
- C) Standards
- D) Procedures

Answer: C **Explanation:** C is correct because standards provide technical specifications implementing policies. The statement names specific tools (SHAP, LIME) and specific parameters (top five features) — this is implementation specification, not a high-level requirement (policy) or step-by-step instructions (procedure). A is wrong because principles are high-level value commitments. B is wrong because a policy would state 'AI systems making credit decisions must provide a human-reviewable explanation' without specifying the technical implementation. D is wrong because a procedure would provide step-by-step instructions for running SHAP/LIME and storing results.

Q5. Scenario: The red team's finding was that the CI/CD pipeline had been modified six months prior to improve deployment speed, and the signature verification step was removed as part of that optimization without governance review. An AI security policy requires that 'model artifacts must be signed and provenance tracked throughout the ML supply chain.' A red team finds that the CI/CD pipeline promotes models to production after pulling artifacts from the model registry without verifying signatures. Which enforcement type is MOST appropriate to prevent future failures?

- A) Audit-based enforcement — conduct quarterly reviews of deployed models to verify signature compliance
- B) Metric-based enforcement — track signature compliance rates by team and report to leadership monthly
- C) Structural enforcement — add an artifact signature verification gate to the CI/CD pipeline before production promotion
- D) Consequence-based enforcement — define penalties for teams that deploy unsigned model artifacts

Answer: C **Explanation:** C is correct because the failure is in the deployment workflow — models are reaching production without signature verification. Structural enforcement embeds the requirement into the technical workflow itself, making bypass visible and requiring explicit override. A is wrong because audit-based enforcement detects violations after deployment but does not prevent them in the pipeline. B is wrong because metric reporting creates accountability but does not prevent the specific workflow failure. D is wrong because consequence design does not prevent the technical failure mode if the workflow allows unsigned artifacts through.

Q6. A compliance officer is reviewing the organization's AI data governance policy and finds that it addresses training data quality and personal data legal basis but does not address data sourced from third parties. Which risk is MOST directly unaddressed by this gap?

- A) Model explainability — third-party data sources reduce the ability to explain model decisions to regulators
- B) Data poisoning — without provenance requirements for third-party data, tampered or manipulated training data cannot be detected
- C) Overfitting — diverse third-party data sources increase the risk that models overfit to training data
- D) Privacy — third-party data has already been anonymized and therefore creates no privacy exposure

Answer: B **Explanation:** B is correct because data provenance policy is the primary control against data poisoning attacks on training data. Without documented lineage and due diligence requirements for third-party data, an organization cannot detect whether training data from external sources has been tampered with or was maliciously constructed. A is wrong because explainability relates to model architecture and output documentation, not data sourcing. C is wrong because overfitting is a technical model quality concern, not a governance risk directly created by third-party sourcing. D is wrong because third-party data anonymization does not eliminate poisoning risk — and anonymized data can still be de-anonymized or manipulated.

Q7. An organization is designing its acceptable use policy for AI. Which element is MOST important to include beyond a list of prohibited uses?

- A) A list of approved AI vendors the organization has pre-qualified for procurement
- B) A defined approval pathway for novel use cases not yet covered by existing permitted or prohibited use categories

- C) A technical architecture diagram showing approved AI deployment patterns
- D) A glossary defining what 'AI' means for purposes of the policy's scope

Answer: B **Explanation:** B is correct because without a pathway for novel use cases, teams encountering an unlisted scenario either wait indefinitely for guidance or proceed without authorization — both are governance failures. The acceptable use policy must close the 'not covered' gap by providing a decision process, not just a binary permitted/prohibited list. A is wrong because approved vendor lists are a procurement control, not part of acceptable use policy scope. C is wrong because architecture diagrams are a standard or procedure-level document, not an acceptable use policy element. D is wrong because a glossary is useful but not the most important missing element when a novel-use pathway is absent.

Q8. A CISO reviews the organization's AI policies and finds they were last updated in 2022. The EU AI Act, NIST CSF 2.0, NIST AI RMF 1.0, and ISO/IEC 42001:2023 all post-date those policies. Which policy maintenance action MOST appropriately addresses this situation?

- A) Replace all existing policies with direct references to the EU AI Act requirements
- B) Conduct a gap analysis against current regulatory requirements and update policies to address identified gaps, archiving previous versions with their effective dates
- C) Keep existing policies in place and issue supplemental guidance memos for each new regulatory requirement
- D) Engage external legal counsel to rewrite all policies to align with the most restrictive interpretation of all applicable frameworks

Answer: B **Explanation:** B is correct because structured gap analysis followed by targeted updates, with version archiving, is the proper maintenance approach. It updates policies to address actual gaps, preserves historical versions for audit traceability, and keeps the policy framework coherent. A is wrong because replacing internal policies with regulatory references does not provide operational guidance; regulations are not procedures. C is wrong because supplemental memos fragment policy coverage and create navigation problems for practitioners. D is wrong because aligning with the most restrictive interpretation of all frameworks creates disproportionate governance burden and may not reflect actual regulatory obligations.

Q9. Which characteristic MOST distinguishes an AI policy that will be followed by practitioners from one that will be treated as a compliance exercise?

- A) Length — longer policies demonstrate greater organizational commitment to governance
- B) Approval authority — policies approved at executive level are more likely to be followed
- C) Specificity, proportionality, justification, and cross-referencing to actionable procedures
- D) Annual reaffirmation — requiring practitioners to sign that they have read the policy ensures awareness

Answer: C **Explanation:** C is correct because the structural characteristics that make policies actionable — specificity (testable requirements), proportionality (requirements scaled to risk), justification (practitioners understand why), and cross-referencing (procedures are findable) — are what distinguish governance that shapes behavior from governance that produces signatures. A is wrong because length

correlates with verbosity, not usability; long vague policies are worse than short specific ones. B is wrong because approval authority creates formal obligation but does not make policies operationally usable. D is wrong because annual reaffirmation creates evidence of awareness but does not change whether the policy provides actionable guidance.

Q10. Scenario: *The audit found that the seven systems with configured monitoring were all deployed by a single team that had received direct CoE implementation support. The other eight were deployed by teams that had received policy documentation but no implementation guidance. An AI governance policy requires that 'operational AI systems must be monitored for performance drift.' A compliance audit finds that eight of fifteen production AI systems have no defined drift threshold or monitoring alert configuration, though all are technically capable of monitoring. Which root cause MOST likely explains this?*

- A) The policy was not approved at a sufficiently senior organizational level to create enforcement obligation
- B) The policy lacks a supporting procedure specifying what drift metrics to measure, what thresholds trigger review, and how to configure monitoring for each risk tier
- C) Practitioners have not received social engineering awareness training and are unaware of the governance risks of ungoverned model drift
- D) The monitoring tools available to the organization are incompatible with the AI systems that lack alert configurations

Answer: B Explanation: B is correct because the pattern described — policy exists, capability exists, but implementation is inconsistent — is the classic symptom of a policy without a supporting procedure. When practitioners can apply a requirement in multiple ways or don't know exactly what to implement, inconsistent application results. A is wrong because approval authority does not explain why the eight systems with capable monitoring were not configured — this is an operational implementation gap, not an authority gap. C is wrong because drift monitoring is a technical configuration task, not a social engineering awareness issue. D is wrong because the audit finding states the systems are 'technically capable of monitoring,' eliminating tool incompatibility.